Semester educational AI gateway rulebook

Status: reference blueprint. The code is a testable catalog-only gateway that fails closed. It is not connected to Semester identity, Supabase, Vercel, a model provider, course records, or production telemetry.

Purpose and non-goals

The gateway mediates every AI request. It may explain approved public materials and return source-labelled, uncertainty-labelled help. It may not receive student records, issue official grades, alter records, enroll/drop, approve financial actions, or replace institutional authority.

Data classes

- `student_record`: grades, transcript, enrollment, student identifiers, accommodations, private notes, financial-aid or conduct data. Never enters provider payloads.
- `student_private`: learner drafts/workspace data. Excluded by this reference; future use needs separate approved policy and minimization review.
- `official_aggregate`: approved non-identifying aggregate with disclosure control. Not enabled in this reference.
- `public_approved`: reviewed public course or platform materials. The only provider-eligible class in this reference.
- `synthetic`: fixtures. Only allowed outside production.

Six interception checks

1. Identity/context: verified server identity; active membership; explicit school context; environment match; canonical assistant authorization.
2. Classification: exact catalog request shape. Free text, attachments, conversation history and record-shaped data are rejected.
3. Policy/consent/budget: institution/course policy, consent, policy version, provider allowance, atomically reserved budget.
4. Retrieval/egress: exact source ID, class, digest and access check; construct minimized provider payload.
5. Route/tools: provider route pinned to environment and approval; reauthorize; tools disabled in this reference.
6. Response/release: catalog output schema only; reauthorize again; recheck source access; render reviewed answer with citation and uncertainty.

Logging

Audit outcome, check/reason code, policy version, environment, model configuration identifier, source IDs and cost/latency metrics. Do not log prompts, answers, tokens, student IDs, source bodies, records or provider raw errors in ordinary telemetry. Separate restricted incident capture requires approved policy.

Failure policy

Fail closed. Dependency outage, unavailable policy, audit write failure, unclear environment or stale authorization produces a refusal code and a support/retry path. Do not send a fallback provider request.

Approval and tools

Future write-capable tools use the standard domain command path: server authorization; impact preview; approval bound to actor, tool, resource, arguments and record version; atomic approval consumption immediately before execution; audit/outbox; receipt; recovery. A model assertion or UI `user_confirmed` flag is not an approval.

Release gate

28 reference tests pass; integration tests against actual identity/RLS/policy/audit adapters; red-team coverage; provider contract review; privacy/security review; accessibility review; environment isolation evidence; incident/runbook rehearsal; human launch approval. Passing this reference suite does not satisfy the gate.